

INTERNATIONAL CYBERSECURITY AND
DIGITAL FORENSICS ACADEMY

Week 1 Practical Laboratory

Information Security Governance in Action

GlobalHealth Connect (GHC) — Executive Governance Simulation

Course	GRC102 – Information Security Governance
Module	Module 1 – Principles of Information Security Governance
Access Window	05–11 September 2026
Due	11 September 2026, 11:59 PM WAT
Maximum Score	100 marks
Gradebook Contribution	10% – Practical Laboratories

Submission mode: Written report + supporting evidence

Scenario-based lab • No terminal or command-line work is required for this laboratory

TASK 1: GOVERNANCE BLUEPRINT

1.1 Current-State Governance Gap Assessment

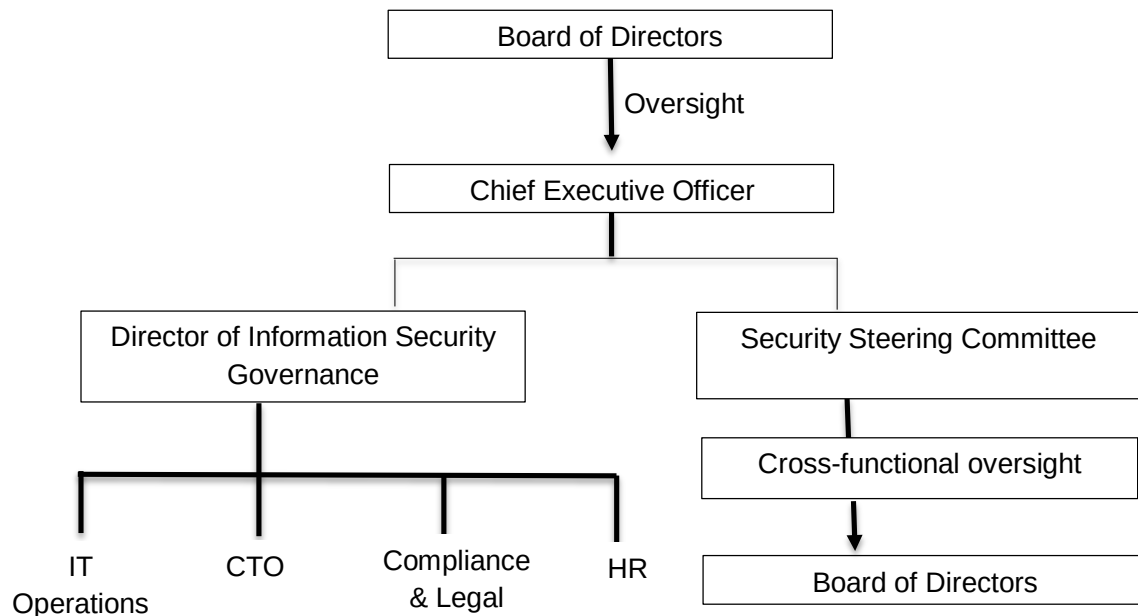
GlobalHealth Connect (GHC) current governance model is largely ad-hoc. This means that security activities are being performed, but they are not supported by a sufficiently formal structure for accountability, decision-making and oversight.

The most important gaps are:

S/N	Governance Areas	Current Weakness	Business Impact
1	Leadership & Accountability	Security ownership and accountability are unclear	Important security decisions may be delayed or made without appropriate authority.
2	Policy framework	Policies are inconsistent and some were inherited from acquisitions.	Employees may follow different security requirements across the organization.
3	Risk Management	Security is largely reactive and there is no formal proactive assessment process.	GHC may identify risks only after an incident or near-miss has occurred.
4	Reporting	Technical metrics exist but are not consistently translated into business impact.	The Board may struggle to understand the actual level of organizational risk.
5	Roles and responsibilities	IT performs several security activities without a sufficiently clear governance structure.	There may be gaps or overlaps in accountability.
6	Compliance	Compliance preparation is mainly audit-driven.	GHC may struggle to demonstrate continuous compliance.
7	Training and awareness	Annual training is mandatory, but engagement is low.	Employees may remain exposed to phishing and other human-related security risks.
8	Security decision making	No formal cross-functional committee exists to resolve competing business and security priorities.	Security decisions may become disputes between technical and business stakeholders.

1.2 Proposed Governance Organizational Structure

The following structure is recommended:



1.3 RACI Responsibility Matrix

Governance Activity	Board	CEO	ISG Director	CTO	IT Manager	Compliance	HR
Security policy approval	A	R	C	C	I	C	I
Enterprise security risk review	A	A	R	C	C	C	I
Security incident response planning	I	A	R	C	R	C	I
Security metrics and board reporting	A	C	R	C	C	C	I
Security awareness programme	I	A	R	C	C	C	R
Compliance monitoring	I	A	R	C	C	R	C
Security standards implementation	I	I	A	R	R	C	I
Security steering committee coordination	I	A	R	C	C	C	C

1.4 How the proposed structure supports accountability, transparency, and business alignment and risk management?

The proposed structure supports accountability because each major governance activity has a clearly identified accountable role. It improves transparency because security information will flow through defined reporting channels rather than remaining within individual departments. It supports business alignment because security decisions involve the CEO, CTO, Compliance and business stakeholders rather than being treated as purely technical matters. It also improves risk management by introducing formal risk reviews, Board reporting and cross-functional decision-making.

This is consistent with the governance principles in the course material, particularly leadership and oversight, strategic alignment, risk management, policy framework, resource management, performance measurement and assurance.

TASK 2: INFORMATION SECURITY CHARTER

2.1 GHC Information Security Charter

1. Purpose

The purpose of the GHC Information Security Programme is to protect the confidentiality, integrity and availability of information and technology resources while supporting the organization's strategic objectives.

As a health-technology organization, GHC depends heavily on customer trust and the protection of sensitive patient information. Information security must therefore support business growth, operational efficiency, innovation and regulatory compliance rather than operate as a separate technical function.

2. Scope

The Information Security Programme applies to:

- GHC employees and contractors;
- Information systems and cloud environments;
- Patient and customer information;
- Financial and business information;
- Applications and infrastructure;
- Information security policies and procedures;
- Third-party service providers;

- Acquired organizations and systems;
- Development and production environments; and
- Other information assets supporting GHC's business operations.

3. Authority

The Information Security Programme operates under the authority of executive management and the Board.

The Director of Information Security Governance is authorized to coordinate the governance programme, identify and escalate significant security risks, monitor compliance with approved requirements and report security matters to executive management and the Board.

Significant security risks that cannot be adequately addressed within existing operational authority should be escalated to executive management and, where appropriate, the Board.

4. Roles and Responsibilities

- The Board provides strategic oversight and ensures appropriate consideration of enterprise security risks.
- The CEO provides executive sponsorship and ensures that information security supports GHC's strategic objectives.
- The Director of Information Security Governance coordinates the security governance programme, reporting, risk oversight and governance processes.
- The CTO and IT Manager are responsible for implementing and maintaining appropriate technical and operational security measures.
- The Compliance Officer supports regulatory compliance and assurance activities.
- The HR Manager incorporates security requirements into employee lifecycle processes.
- All employees and relevant third parties are responsible for complying with approved security requirements.

5. Key Principles

GHC's Information Security Programme will be based on the following principles:

- **Risk-based:** Security decisions will be based on identified and assessed risks.
- **Business-aligned:** Security should support GHC's business objectives rather than unnecessarily prevent business activities.
- **Proportionate:** Security controls should reflect the level and nature of the risk.

- **Accountable:** Security responsibilities must be clearly assigned.
- **Continuous improvement:** The programme will be regularly reviewed and improved.
- **Protection of customer trust:** Protecting patient and customer information remains a key priority.
- **Regulatory awareness:** Applicable healthcare and data-protection obligations will be proactively considered.

6. Reporting Structure

- The Information Security Governance function will provide regular reporting to executive management.
- The Security Steering Committee will review significant security risks, initiatives, policy matters and cross-functional issues.
- The Board will receive concise reporting focused on security posture, significant risks, trends, business impact and required decisions.

7. Review and Approval

This Charter will be approved by executive management and reviewed at least annually or when significant organizational, regulatory, technological or risk changes occur.

Changes to the Charter will be subject to appropriate management approval and documented change control.

2.2 Justification Memo to the CFO

To: Marcus Thorne, Chief Financial Officer

From: Director of Information Security Governance

Subject: Justification for the GHC Information Security Charter

The Information Security Charter provides GHC with a formal structure for managing information security as an enterprise responsibility rather than treating it solely as an IT issue. This is particularly important as GHC expands its market share, integrates acquisitions and develops new AI-driven and digital-health capabilities.

The Charter also provides a clearer basis for investment decisions. Rather than requesting security resources simply because a technical team identifies a need, investment can be linked to business risk, regulatory requirements, operational efficiency and customer trust. This allows management to better understand why security expenditure is required and what risk it is intended to reduce.

The Charter directly supports GHC's 2026 strategic goals by protecting patient information, supporting system availability, enabling innovation and strengthening regulatory preparedness. GHC's stated objectives include expanding its client base by 25%, achieving 99.99% system uptime, protecting customer trust and proactively meeting applicable regulatory obligations.

TASK 3: BOARD REPORTING AND SECURITY METRICS

3.1 Board Executive Summary

Overall Security Posture: RED

GHC's current security posture should be rated "RED" because several indicators are moving in an unfavorable direction simultaneously.

Phishing incidents increased from 150 in September to 320 in February, representing more than a doubling over the six-month period. Malware incidents also increased from 25 to 50. At the same time, the percentage of critical vulnerabilities patched declined from 67% to 55%, while high-risk incidents increased from two to seven.

Although employee training completion improved from 45% to 70%, the improvement has not yet translated into an overall improvement in the security risk position. The increase in high-risk incidents suggests that GHC's exposure remains significant.

The Board should therefore priorities vulnerability remediation, incident reduction, and security governance and employee security behavior.

3.2 Selected Board Metrics

Metric	September	February	Trend	Business Commentary
Phishing incidents	150	320	Unfavorable	Indicates increasing exposure to social-engineering threats.
Malware incidents	25	50	Unfavorable	Malware events doubled and require management attention.
Critical vulnerabilities patched	67%	55%	Unfavorable	Remediation performance is declining despite increasing exposure

Security training completion	45%	70%	Positive	Awareness participation is improving but remains incomplete.
High-risk security incidents	2	7	Unfavorable	Indicates increasing material security exposure.

3.3 Priority Risks

Risk 1: Increasing High-Risk Security Incidents

High-risk incidents increased from two to seven during the reporting period. If the trend continues, GHC could face greater operational disruption, data loss, reputational damage and regulatory consequences.

Risk 2: Declining Critical Vulnerability Remediation

Critical vulnerability patching declined from 67% to 55% while the number of vulnerabilities requiring remediation increased. This creates a growing window during which known vulnerabilities may remain exploitable.

3.4 Recommendations

- **Recommendation 1: Establish a critical vulnerability remediation programme.**

GHC should establish clear remediation targets based on vulnerability severity, assign ownership to system owners and report overdue critical vulnerabilities to the Security Steering Committee.

- **Recommendation 2: Strengthen phishing and security-awareness activities.**

Training should move beyond annual completion and include targeted awareness activities, phishing simulations and role-specific education.

- **Recommendation 3: Establish Board-level security risk reporting.**

The Board should receive a concise dashboard covering major security risks, control performance, incident trends and management actions.

3.5 Metric Selection Rationale

The five selected metrics provide a balanced picture of GHC's security position. Phishing and malware show threat activity, vulnerability patching measures a key preventive control, training completion measures employee preparedness and high-risk incidents demonstrate the overall severity of security events.

This approach is preferable to providing the Board with a long list of technical indicators because the objective of Board reporting is to support strategic decision-making and oversight.

TASK 4: SECURITY STEERING COMMITTEE

4.1 Terms of Reference

Purpose

The Security Steering Committee (SSC) will provide cross-functional oversight of GHC's information security programme and ensure that security decisions remain aligned with business priorities, risk appetite and regulatory obligations.

Scope

The SSC will oversee:

- Information security risks.
- Security policies and standards.
- Major security initiatives.
- Security performance metrics.
- Incident preparedness.
- Compliance and regulatory matters.
- Security awareness.
- Major technology and security investments.

Membership

Recommended membership includes:

- CEO or executive sponsor – Chair
- Security Governance Lead – Secretariat
- CTO
- IT Manager
- Compliance Officer
- HR Manager

- Finance/Data representative
- Relevant business representatives when required

Responsibilities

The Committee will:

1. Review significant security risks.
2. Review security performance metrics.
3. Recommend security policies and major changes.
4. Review security incidents and lessons learned.
5. Resolve cross-functional security issues.
6. Review security investment priorities.
7. Monitor progress against the governance roadmap.
8. Escalate significant risks to executive management and the Board.

Meeting Cadence

The SSC should meet monthly during the initial implementation period and may move to quarterly once the governance structure becomes established.

Emergency meetings may be called when significant security incidents or urgent decisions arise.

Decision Authority

The SSC may make recommendations and approve matters within its delegated authority. Matters involving significant risk acceptance, material investment, major policy changes or strategic risk should be escalated to executive management or the Board.

Reporting

The SSC will maintain meeting minutes, decision records, action trackers and risk escalations. A summary should be included in regular executive and Board reporting.

4.2 First SSC Meeting Agenda

Meeting: Security Steering Committee – First Meeting

1. Opening and introductions.
2. Purpose and Terms of Reference.
3. Review of current GHC security posture.

4. Review of major security risks.
5. Password policy dispute:
 - Proposed 16-character complex passwords.
 - Mandatory change every 30 days.
 - Lack of password-manager integration.
 - CTO's recommendation to emphasize MFA and secure password management.
6. Risk and business-impact assessment of the proposed approaches.
7. Decision/recommendation on password policy.
8. Security metrics and Board reporting.
9. Governance roadmap.
10. Action items and owners.
11. Date of next meeting.

The password-policy discussion should focus on the actual risk being addressed rather than simply choosing between two competing technical preferences. A balanced approach should consider the effectiveness of authentication controls, usability, implementation cost and the organization's overall risk profile.

4.3 Briefing Note to the CEO

The Security Steering Committee will provide GHC with a structured forum for resolving security issues that involve multiple departments. The password-policy disagreement demonstrates why this is necessary. IT may focus on stronger technical controls while development may be concerned about usability and productivity. The Committee creates a mechanism for both perspectives to be considered alongside business risk, compliance requirements and operational impact.

The SSC will also improve strategic alignment by ensuring that significant security decisions are documented, assigned to accountable owners and escalated when necessary. This reflects the governance approach promoted by COBIT 2019, where governance provides direction and oversight while management implements the decisions.

TASK 5: GOVERNANCE MATURITY ASSESSMENT

5.1 Current Maturity Assessment

The GHC maturity assessment uses the five-level model provided in the laboratory brief, ranging from Level 1 (Ad Hoc) to Level 5 (Optimizing).

Governance Domain	Current Level	Assessment
Policy & Documentation	2 – Initial	Policies exist but are inconsistent, inherited from acquisitions and not always current.
Roles & Responsibilities	1 – Ad Hoc	Security ownership and accountability are unclear.
Risk Management	1 – Ad Hoc	Risk management is mainly reactive and lacks a formal proactive assessment process.
Metrics & Reporting	2 – Initial	Technical metrics exist but are not consistently translated into business impact.
Training and awareness	2 – Initial	Mandatory annual training exists, but engagement is low.
Compliance	1 – Ad Hoc	Compliance activity is primarily audit-driven rather than continuously monitored.

Overall, GHC's governance maturity is approximately Level 1–2, meaning that some security processes exist but are not yet consistently structured, documented or governed.

5.2 12–18 Month Maturity Roadmap

Initiative 1: Establish Formal Security Governance

Objective: Create clear security accountability and decision-making structures.

Activities:

- Approve the Information Security Charter.
- Establish the Security Steering Committee.
- Define governance roles.
- Implement the RACI matrix.
- Establish Board reporting.

Expected Outcome: All major security governance activities have clearly assigned owners and escalation routes.

Initiative 2: Standardize Security Policies

Objective: Create a consistent policy framework across GHC and its acquired businesses.

Activities:

- Review existing policies.
- Identify outdated and conflicting documents.
- Establish policy ownership.
- Create approval and review schedules.
- Communicate approved policies to employees.

Expected Outcome: Critical security policies are documented, approved, communicated and reviewed at defined intervals.

Initiative 3: Implement Proactive Security Risk Management

Objective: Move from reactive risk management to a structured and proactive approach.

Activities:

- Establish a security risk register.
- Define risk assessment methodology.
- Assign risk owners.
- Establish treatment plans.
- Report significant risks to the SSC and Board.

Expected Outcome: Material security risks are formally identified, assessed, owned and monitored.

This approach is consistent with the risk-management emphasis of ISO/IEC 27001 and the NIST CSF's focus on understanding and managing cyber security risks (ISO, 2022; NIST, 2024).

Initiative 4: Develop Board-Level Security Metrics

Objective: Translate technical security information into business-relevant information.

Activities:

- Define key security metrics.
- Establish data owners.
- Develop a security dashboard.
- Introduce trend analysis.
- Include risk and business impact in Board reporting.

Expected Outcome: The Board receives regular, consistent and decision-useful security information.

Initiative 5: Strengthen Security Awareness and Continuous Compliance

Objective: Improve employee security behavior and reduce reliance on annual compliance activities.

Activities:

- Conduct targeted security awareness campaigns.
- Introduce phishing simulations.
- Develop role-specific training.
- Monitor completion and effectiveness.
- Establish continuous compliance monitoring.

Expected Outcome: Improved employee engagement and better evidence of ongoing compliance.

5.3 Board Executive Summary

GHC currently operates at a relatively low level of information security governance maturity. Policy and documentation and metrics/reporting are at Level 2, while roles and responsibilities, risk management and compliance are assessed at Level 1. Training and awareness is assessed at Level 2. These ratings reflect the evidence that policies are inconsistent, accountability is unclear, risk management is reactive, technical metrics are not consistently translated into business impact, employee engagement is low and compliance remains largely audit-driven.

The proposed 12–18 month roadmap is designed to move GHC to at least Level 3 (Defined) across all six domains. Achieving this level would mean that security processes are documented, standardized, communicated and supported by clear responsibilities. This is important because GHC's strategic growth, cloud-based operations, acquisitions and plans for AI-driven innovation increase the need for consistent security governance.

The roadmap should therefore be viewed as a business-enablement initiative rather than simply an IT improvement programme. Stronger governance can help GHC make better risk-based investment decisions, protect customer trust, support regulatory compliance and provide a more consistent foundation for future growth.

CONCLUSION

The GHC scenario demonstrates why information security governance needs to be treated as an organizational responsibility rather than solely a technical function. The current ad-hoc approach has created gaps in accountability, risk management, policy consistency, reporting and compliance.

The proposed governance structure introduces clearer accountability through the Board, CEO, Security Governance Lead and Security Steering Committee. The Information Security Charter provides a formal mandate, while the Board reporting model translates security information into business-relevant indicators. The Security Steering Committee provides a mechanism for resolving cross-functional issues, and the maturity roadmap establishes a structured path towards a defined governance environment.

The recommendations are consistent with established governance principles. COBIT 2019 emphasizes enterprise-wide governance, stakeholder value and the distinction between governance and management (ISACA, 2019). ISO/IEC 27001:2022 provides a structured approach to information security management, risk management and continual improvement (ISO, 2022). NIST CSF 2.0 provides an additional framework for helping organizations manage and communicate cybersecurity risk (NIST, 2024).

Ultimately, GHC's objective should not be to create security processes simply for compliance purposes. The objective should be to establish a governance system that helps the organization make informed decisions, manage security risks, protect sensitive information and support sustainable business growth.

References

International Organization for Standardization. (2022). *ISO/IEC 27001:2022 information security, cybersecurity and privacy protection—Information security management systems—Requirements*. ISO.

ISACA. (2019). *COBIT 2019 framework: Governance and management objectives*. ISACA.

National Institute of Standards and Technology. (2024). *The NIST Cybersecurity Framework (CSF) 2.0* (NIST Cybersecurity White Paper 29). U.S. Department of Commerce. <https://doi.org/10.6028/NIST.CSWP.29>